

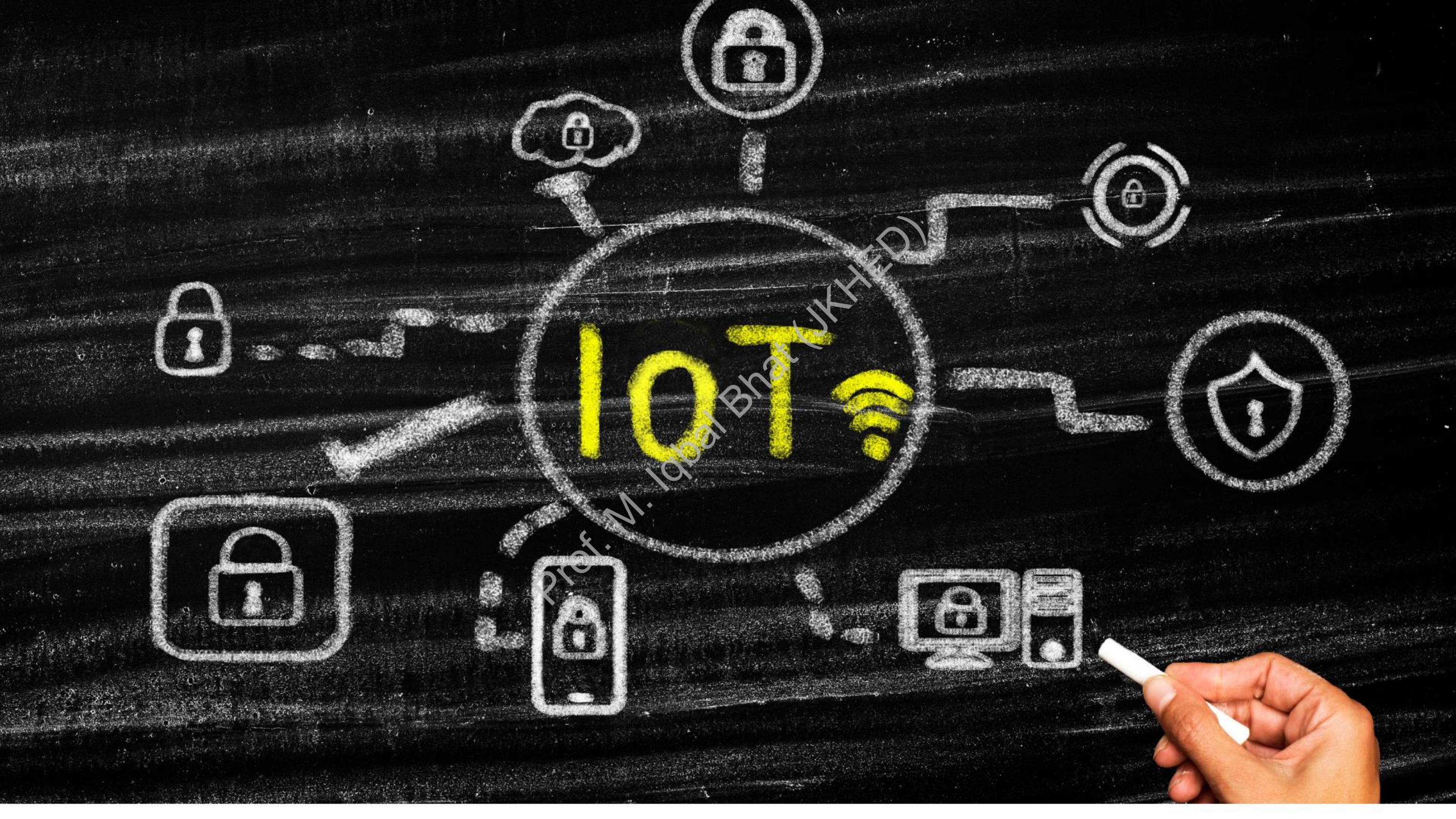


SECURITY & PRIVACY

Explore the critical challenges and considerations around securing the rapidly expanding Internet of Things (IoT) ecosystem. Understand the importance of protecting sensitive data and user privacy as more devices become interconnected.

By
Prof. Muhammad Iqbal Bhat
GDC Beerwah

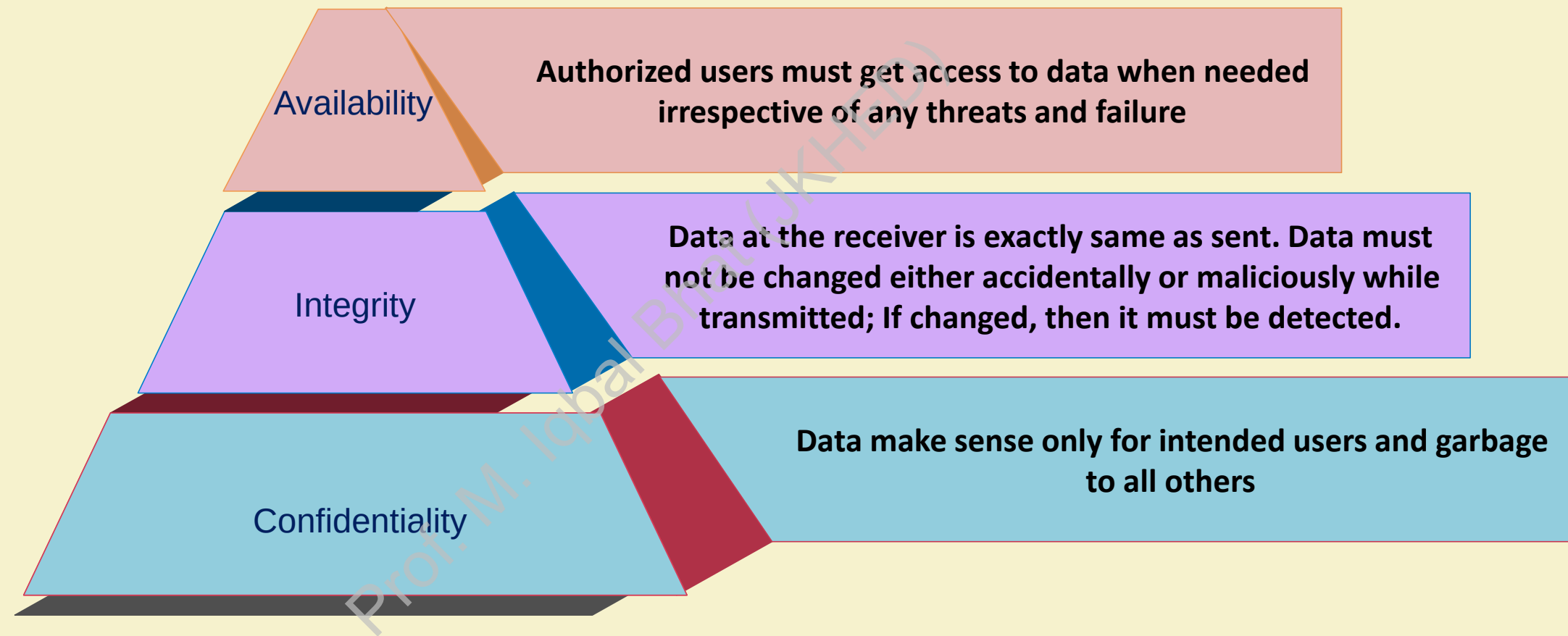




Need for IoT Security

- ↗ Network of resource-constrained devices with low-bandwidth channels
- ↗ Devices with heterogeneous storage and processing capability
- ↗ Exposed to large attack surface
- ↗ Threats from hazards, device malfunctions and human errors
- ↗ Risks of Industrial accidents, disclosure of sensitive data and interrupted operations

Basic Security Goals

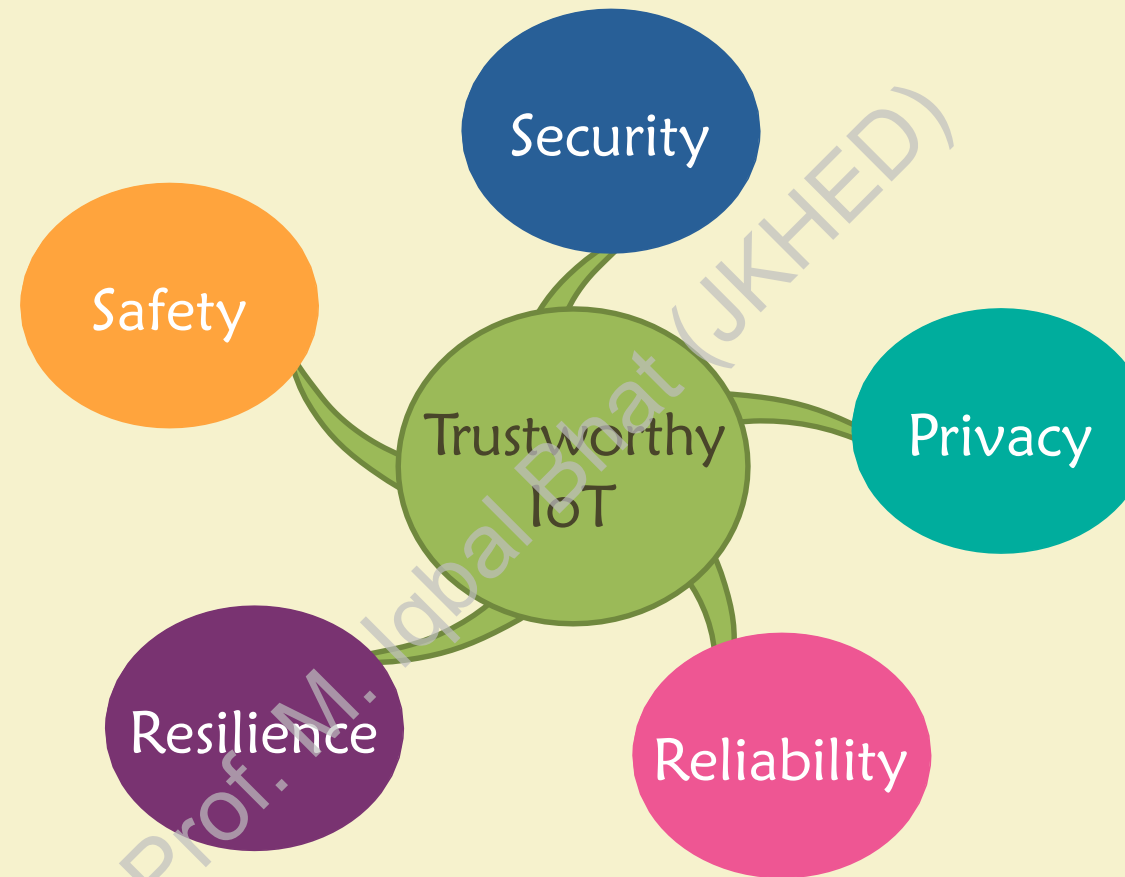


Source: "An Introduction to Information Security", NIST

Trustworthy IoT

Safe operations of device and people without any risks and injury

Ability of the system to function correctly on dynamic adversarial conditions



Protecting the system from Unauthorized access, modification and destruction

Restriction on data access - who can access and by whom it can be disclosed

Ability of the system to perform under stated conditions correctly for the specified time period

Security In IIoT: Distinguished Aspects

- IIoT brings Information Technology (IT) and Operational Technology (OT) together
- Traditional security techniques working independently for IT and OT are no more applicable
- Simply integrating features from IT and OT is not possible
- Information security and device security
- Inadequate regulatory framework and standards.

IT and OT Security Requirement

- Current security architectures are mostly IT-centric
- Security assumptions for client-server model with well known communication protocols such as IP, TCP and HTTP.
- Assumes some well-known attacks and attack models
- OT systems only deploy legacy physical security protections
- Out-dated security protection for isolated OT networks
- Security for OT integrated with IT components ignored

Cloud Complied IIoT Security Requirement

- OT infrastructure is controlled and managed at external networked cloud
- Data from thousands of devices stored in cloud
- Third-party services with trust-boundaries for security and privacy
- Safeguarding the control systems from incoming cloud information flow

IoT Security Risk Management

01

Avoiding risks

02

Mitigating risks

03

Outsourcing risks

04

Accepting risks

05

Balancing residual risks

Classes of Attackers

- Outsourced firms
- Hardware vendors
- Third-party service providers like cloud vendors
- Internal unethical employees
- Organized crime groups

STRIDE Threat Model

S	Spoofing	Involves illegally accessing and then using another user's authentication information, such as username and password
T	Tampering	Involves the malicious modification of data. Examples include unauthorized changes made to persistent data, such as that held in a database
R	Repudiation	Associated with users who deny performing an action without other parties having any way to prove otherwise
I	Information disclosure	Involves the exposure of information to individuals who are not supposed to have access to it
D	Denial of service	Denial of service (DoS) attacks deny service to valid users—for example, by making a Web server temporarily unavailable or unusable.
E	Elevation of privilege	An unprivileged user gains privileged access and thereby has sufficient access to compromise or destroy the entire system.

Source: "IoT Security Architecture | Microsoft Docs", Microsoft Azure

IoT Attack Surface

Application

- Data stores
- Interfaces
- Application software

Network

- Gateway devices
- Local intelligent devices
- Routers

Physical

- Sensors and actuators
- Industrial process control devices

Source: "IoT Attack Surface Areas", OWASP

IoT Attack Vectors: Application Layer

- ↗ Data spoofing An attack where false data is injected into an IoT system, misleading it into accepting it as legitimate
- ↗ SQL injection A cybersecurity threat where an attacker manipulates a standard SQL query to access and manipulate the database of an IoT application.
- ↗ DoS or DDoS Attacks that overwhelm an IoT network with traffic, rendering it unable to process legitimate requests
- ↗ Replay attack A network attack where a valid data transmission is maliciously or fraudulently repeated or delayed
- ↗ Resource exemption A security strategy that involves excluding certain IoT devices from security checks due to their limited processing capabilities
- ↗ Reversal attack A method where attackers analyze IoT device firmware to discover vulnerabilities and exploit them

Source: IoT Attack Surface Areas”, OWASP

IIoT Attack Vectors: Network Layer

- ↗ Traffic flooding A type of Distributed Denial of Service (DDoS) attack that overwhelms an IIoT network with excessive traffic, leading to service disruption
- ↗ Man-in-the-middle attack A cyberattack where the attacker secretly intercepts and possibly alters the communication between two parties in an IIoT system
- ↗ Misrouting A security issue where IIoT data packets are intentionally redirected to an incorrect destination, potentially leading to data loss or interception
- ↗ Packet sniffing The unauthorized capture and analysis of IIoT data packets traveling through a network to gain sensitive information
- ↗ Resource exemption A security practice in IIoT where certain resource-constrained devices are exempted from standard security protocols due to their limited capabilities

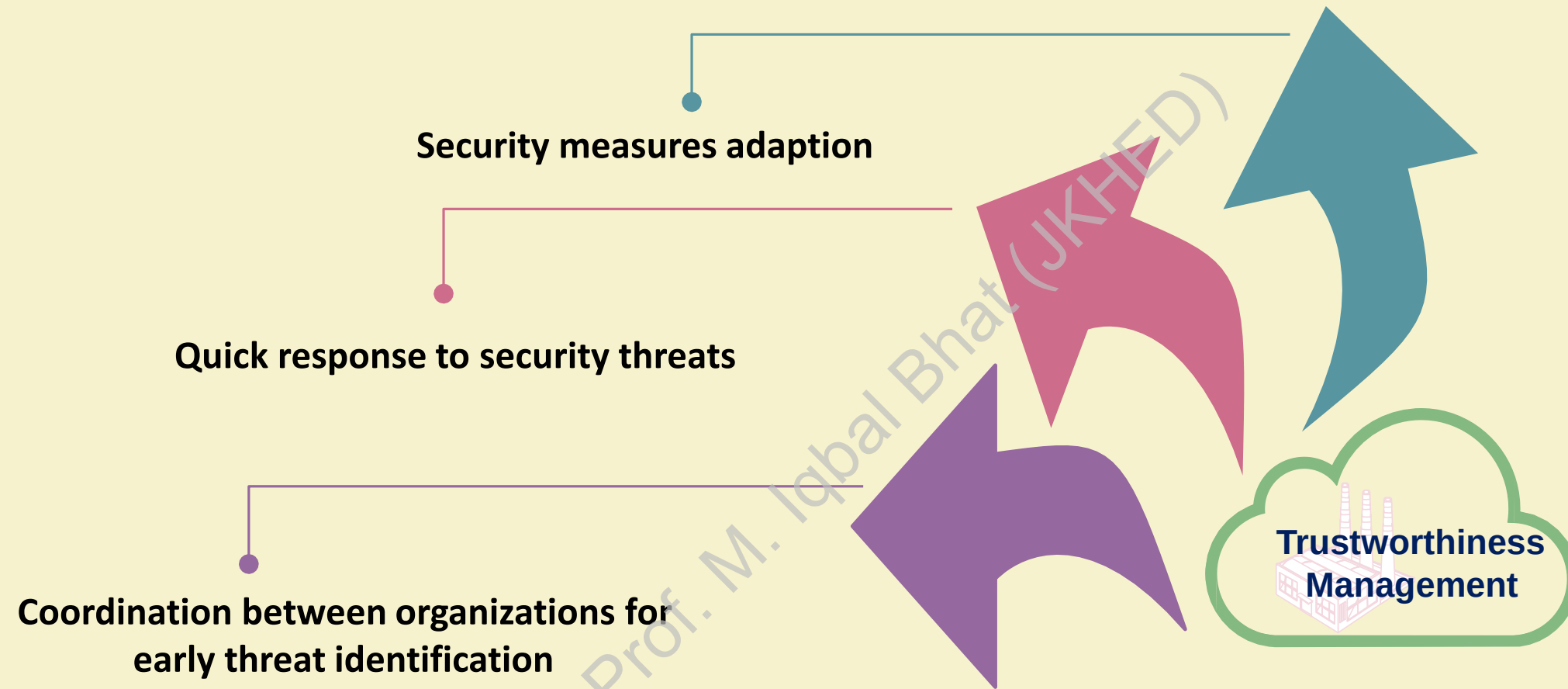
Source: IIoT Attack Surface Areas”, OWASP

IoT Attack Vectors: Physical Layer

- ↗ Impersonation attack A security breach where an attacker masquerades as a legitimate user or device to gain unauthorized access to information or systems in an IoT network
- ↗ Jamming attack A disruptive tactic where an attacker floods the network with interference, preventing IoT devices from communicating effectively
- ↗ Device tampering Refers to the unauthorized alteration or manipulation of an IoT device's hardware or software, compromising its integrity and security

Source: IoT Attack Surface Areas", OWASP

Trustworthiness Management



Source: "Industrial Internet of Things Volume G4: Security Framework", Industrial Internet Consortium

Security requirements for IIoT

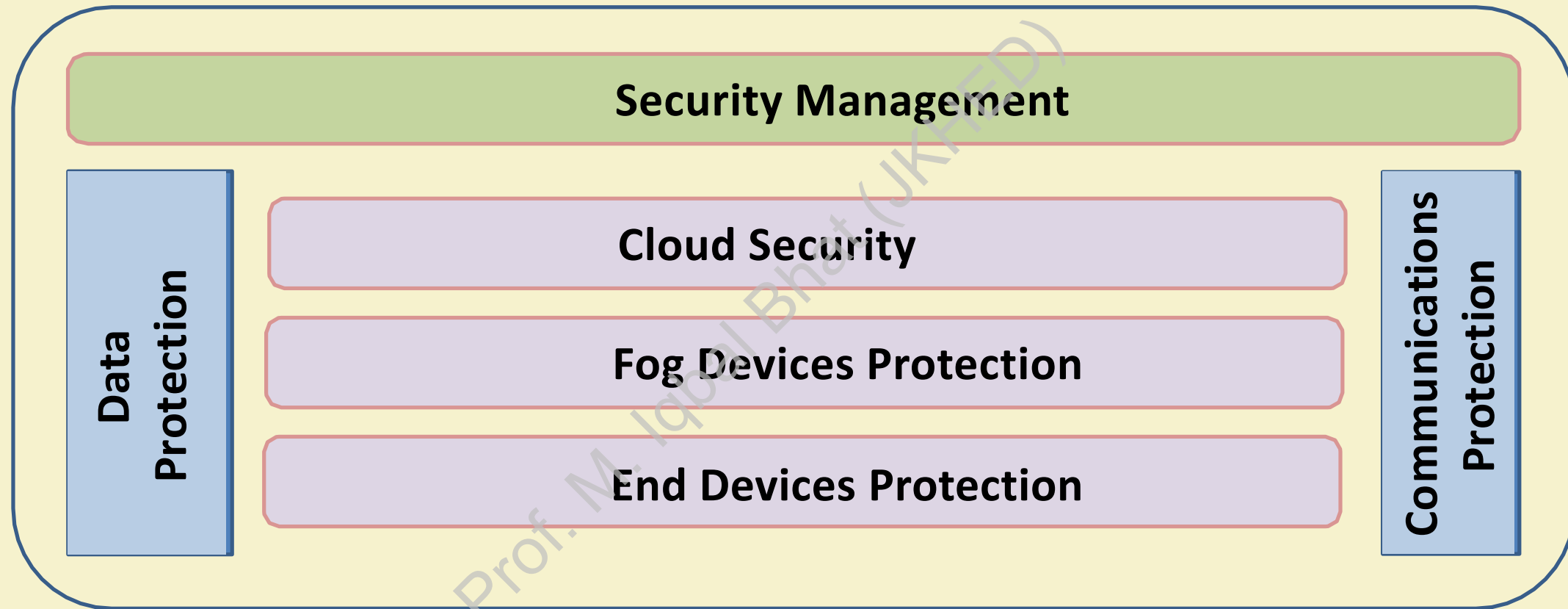
- End-to-end security is the primary requirement of IIoT
- Both horizontal and vertical security are important
- Security of the whole system depends:
 - Security of deployed devices
 - Communication security
 - Data protection
 - Security management

Security Framework for IIoT

- ↗ Every industrial application of IIoT must have a security framework with its own requirements and solutions
- ↗ The framework should address:
 - ↗ Different security issues in IIoT
 - ↗ Trustworthy IIoT System
 - ↗ Major security building blocks of IIoT
 - ↗ Techniques for securing each independent block and secure integration

Source: "Industrial Internet of Things Volume G4: Security Framework", Industrial Internet Consortium

IIoT Security Building Blocks:

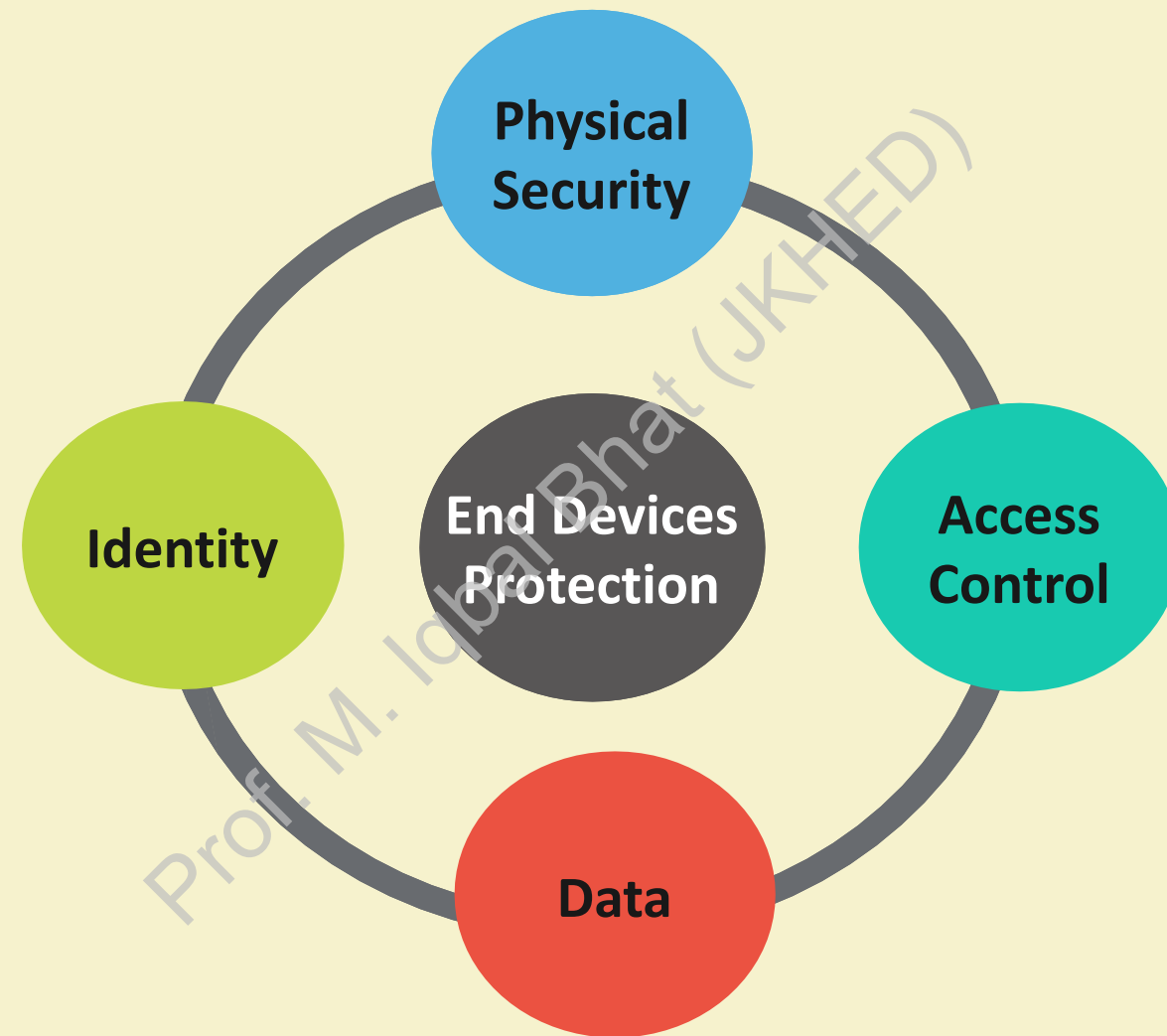


Source: "Industrial Internet of Things Volume G4: Security Framework", Industrial Internet Consortium and "Security for the Industrial Internet of Things", Accenture

End Devices Protection - Challenges

- ↗ Devices: sensors, actuators, machines and many small embedded devices
- ↗ Resource constrained
- ↗ Many devices are mobile
- ↗ Heterogeneous
- ↗ No support for standard cryptographic protocols

End Devices Protection - Requirement



Source: "Industrial Internet of Things Volume G4: Security Framework", Industrial Internet Consortium

End Devices Protection - Solutions

- ↗ Lightweight cryptographic protocols
 - ↗ Energy efficient authentication
 - ↗ Lightweight symmetric key cryptography
- ↗ IDS and behavior analysis at upper layer devices
 - ↗ Malicious behavior detection
 - ↗ Abnormal data traffic detection
 - ↗ Mitigation using proper actuation unit and signals

Source: Pacheco et al., 2017 and
“Lightweight Cryptography for the Internet of Things”, Sony Corporation

Fog Devices Protection

- ↗ Devices deployed near to end devices capable of notable computing and storage
- ↗ Requirements are same as end devices
- ↗ Standard cryptographic protocols for:
 - ↗ Authentication between fog devices
 - ↗ Authentication between fog devices and cloud
- ↗ Lightweight cryptography for security between for authenticating end devices

Source: Pacheco et al., 2017

Cloud Security

↗ Cloud is the data and control hub of the IIoT system

↗ Security requirement for :

↗ Data protection

↗ Applications

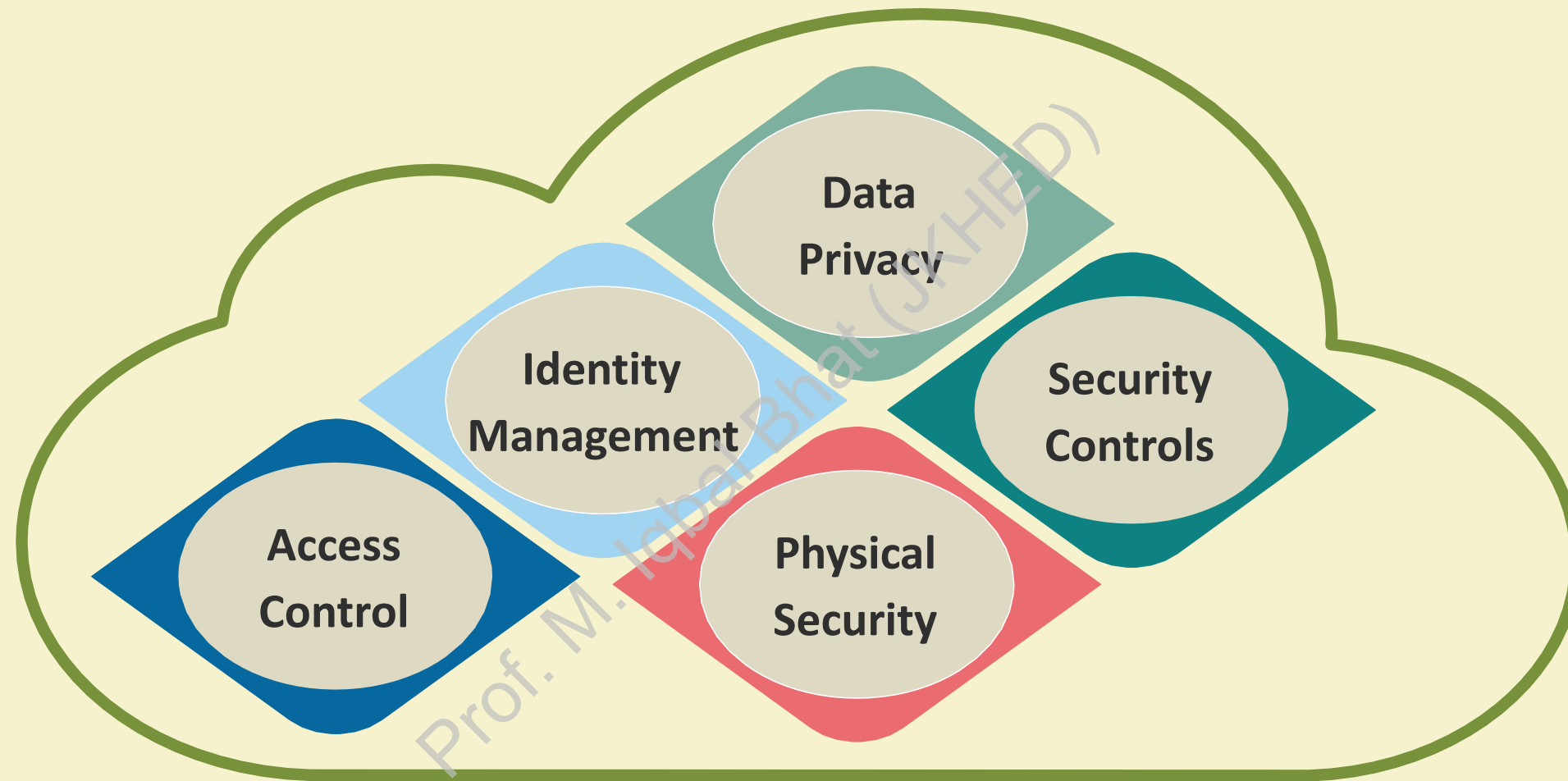
↗ Cloud infrastructure

↗ Limiting the service provider access

↗ Access control for cloud resources

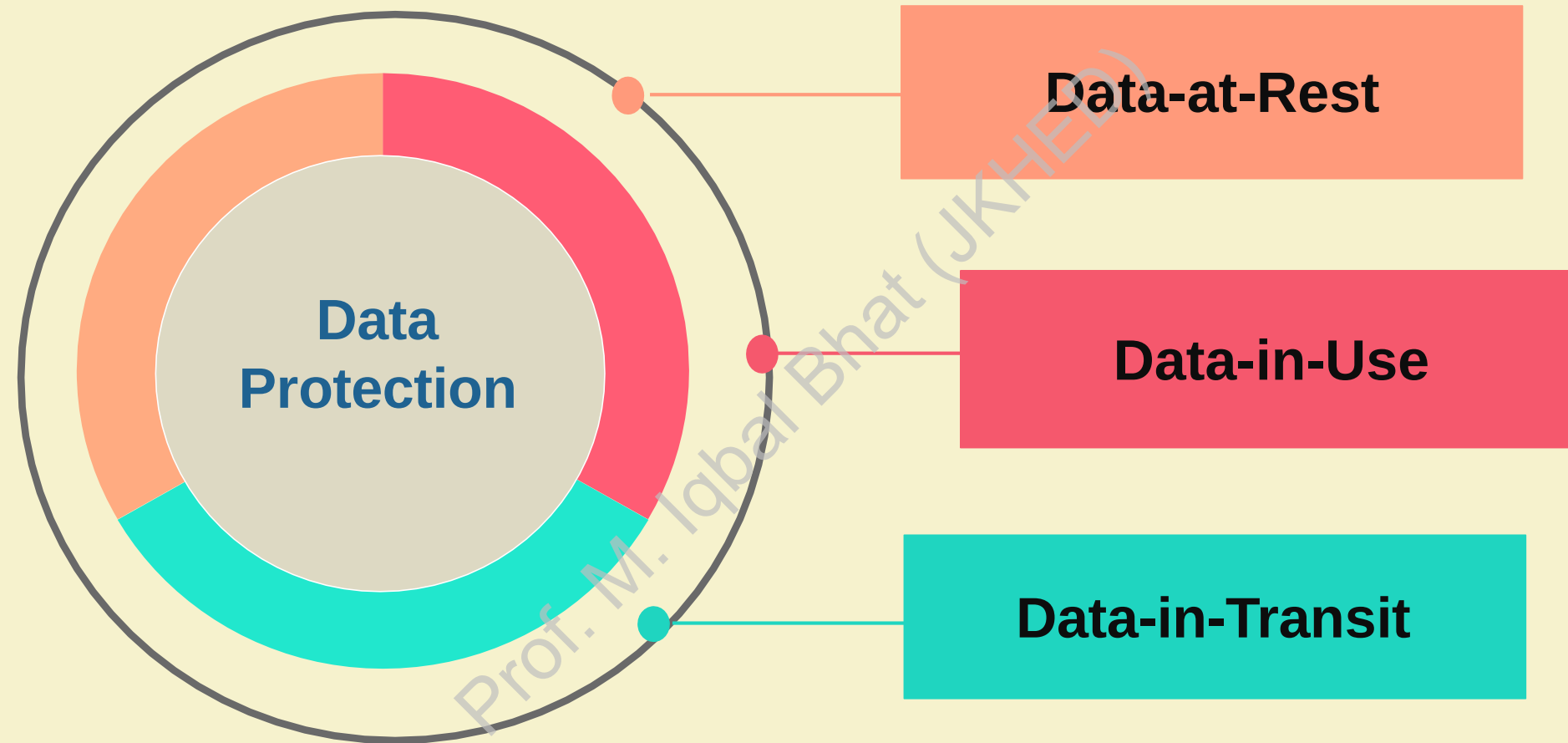
Source: "Cloud computing security", Wikipedia

Cloud Security



Source: "Cloud computing security", Wikipedia,

Data Protection



Source: "Industrial Internet of Things Volume G4: Security Framework", Industrial Internet Consortium

Data Protection

- ↗ The most sensitive part of IIoT is data
- ↗ Different data sources and types with their own lifecycle, risks and security challenges
- ↗ Data protection includes:
 - ↗ Confidentiality
 - ↗ Integrity
 - ↗ Availability

Source: “An Introduction to Information Security”, NIST

Communications Protection

- Secure exchange of information between IIoT devices
- Different security risk: sensor data, commands, actuation signals, log reports, configuration messages, etc.
- IIoT traffic and data formats are different from core network
- Protection involves:
 - Communication with devices at the same layer
 - Communication with devices at upper or lower layer

Communications Protection Techniques

- ↗ Network access control
- ↗ Security gateways
- ↗ Network firewalls
- ↗ Cryptographic protocols with:
 - ↗ Strong mutual authentication
 - ↗ Authorization mechanism
 - ↗ Data ciphering

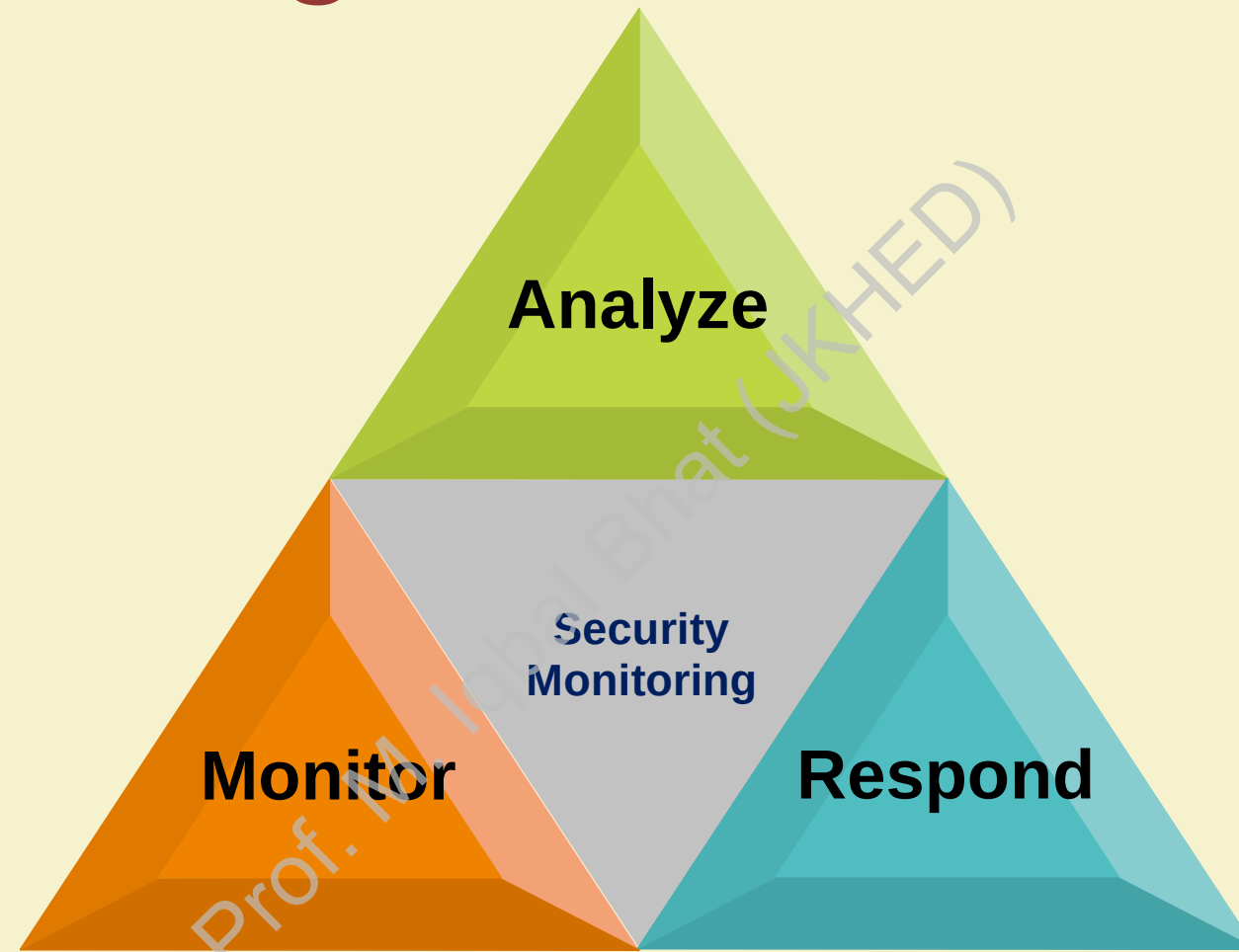
Source: Pacheco et al., 2017

Security Management

- ↗ Deals with configurations, periodic updates and managing the security controls
- ↗ An active unit, functions from establishment to end of entire IIoT system
- ↗ Prevention, detection, analysis and mitigation of security risks
- ↗ Performs security monitoring, policy management and updates over time as per standards

Source: "Industrial Internet of Things Volume G4: Security Framework", Industrial Internet Consortium

Security Monitoring



Source: "Industrial Internet of Things Volume G4: Security Framework", Industrial Internet Consortium

Regulatory Standards for IIoT Security

- A security standard helps in achieving a common level of security in industries
- Standards help for manufacturers and vendors to offer services at different level of security
- For IIoT, security standards should include requirements of IT and OT
- Till date, there is no security standards specific to IIoT

Standards Related to IIoT Security

IT Security

- ISO/IEC 154083: Common Criteria for Information Technology Security Evaluation
- ISO series of standards for privacy, framework and regulations
- ISO 27017, NIST SP 800-144, ENISA standard: Cloud security standards
- Common criteria and Federal Information Processing Standard (FIPS)

OT Security

- IEC 62443: Industrial automation and control systems security
- NIST SP 800-82: Security in Industrial Control Systems
- NERC-CIP: Critical infrastructure protection
- IEEE 1686: Standard for Intelligent Electronic Devices Cyber Security Capabilities
- NISTIR 7628: Guidelines for Smart Grid Cyber Security

Source: "Industrial Internet of Things Volume G4: Security Framework", Industrial Internet Consortium

Conclusion and Best Practices for IoT Security

1 **Adopt a Holistic Security Approach**

Securing IoT devices requires addressing security at every layer - hardware, firmware, software, and network protocols. Implement a comprehensive strategy that addresses all potential vulnerabilities.

3 **Implement Strong Authentication and Encryption**

Use robust authentication methods like multi-factor authentication and end-to-end encryption to protect IoT data and prevent unauthorized access to devices.

2 **Prioritize Firmware and Software Updates**

Regularly update IoT device firmware and software to patch known vulnerabilities and enhance security features. Automate updates to ensure devices are always running the latest secure versions.

4 **Educate Users on Security Best Practices**

Provide clear guidance to IoT device users on how to securely configure and use their devices to minimize risk and maintain privacy.

